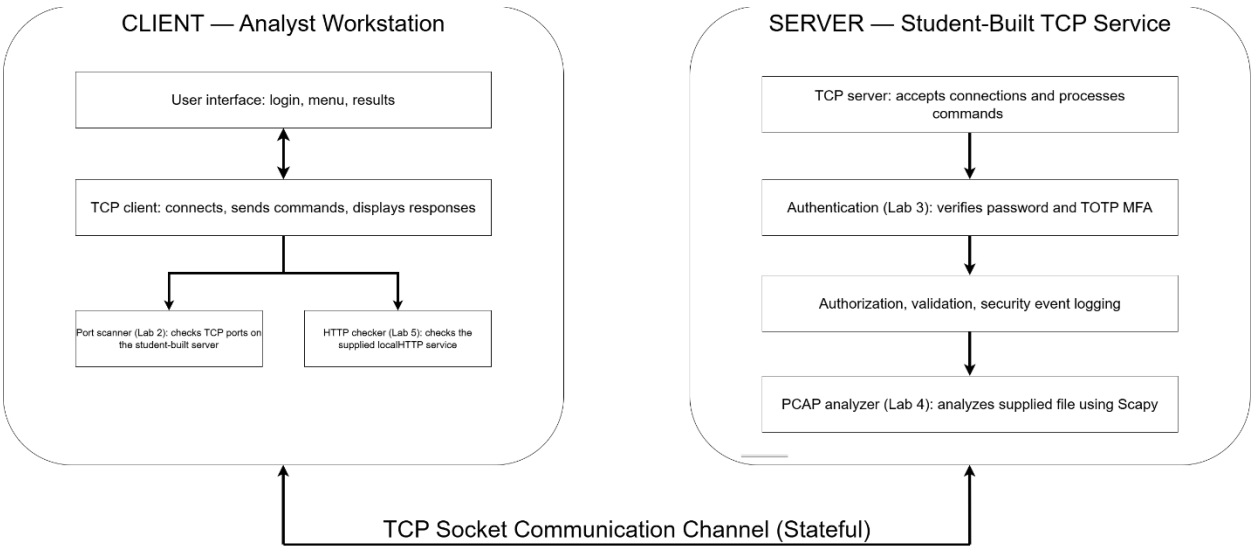
MIDTERM EXAM | OPERATION SENTINEL — SECURE SERVER ASSESSMENT

Day 1 — Architecture and Threat Modeling

Part A — Architecture Design

System architecture diagram



Component Responsibilities

Client:

- User Interface: Manages user inputs and displays processed responses received from the server.
- TCP Client: Establishes a TCP connection with the server and formats user operations into delimiter-based application-layer protocol commands.
- Port Scanner (Lab 2): Scans open TCP ports on the target service using raw sockets or python-nmap.
- HTTP Checker (Lab 5): Evaluates the local test HTTP service for any and exports the findings into a CSV report.

Server

- TCP Server: Listens on designated ports and accepts incoming client socket connections.

- Authentication (Lab 3): Validates user passwords and verifies Time-based One-Time Passwords.
- PCAP Analyzer (Lab 4): Processes synthetic traffic PCAP files, tracking packet counts and implementing a sliding time window mechanism to detect suspicious IP behavior.
- Event Logging: Enforces access control policies and logs security events and connection activities.

Information Flows

The client connects to the server via a TCP socket, performs a multi-step authentication handshake (submitting AUTH and OTP commands), and then exchanges chat messages or requests security analyses over the established connection.

Rationale for Stateful Interaction Model

I used stateful interaction model because the server needs to track authentication and MFA verification states throughout the TCP session. This ensures that unauthenticated clients are strictly blocked from executing sensitive commands before logging in.

Part B — Adversarial Threat Model

Domain	**Asset**	**Attack Vector**	**Impact**	**Mitigation**	**Residual Risk**
Sockets	TCP Channel	Sniffing plaintext traffic over the local network.	Credential or message data leakage.	Restrict testing to loopback (127.0.0.1	Vulnerable to host-level memory reading.
Scanning	Port Scanner	Scanning unauthorized external target IPs.	Triggers IDS alerts or DoS complaints.	Restrict scanning to authorized targets.	User manually bypasses script checks.
Auth/MFA	Auth Module	Brute-forcing passwords or TOTP codes.	Unauthorized access to server.	Password hashing.	Client device loss.

Domain	Asset	Attack Vector	Impact	Mitigation	Residual Risk
Scapy	PCAP Analyzer	Submitting malformed or oversized PCAP files.	Server script crash or denial of service (DoS).	Strict blocks with threshold limits.	Undisclosed zero-day bugs in Scapy.
HTTP	HTTP Checker	Exploiting configuration flaws in test web service.	Information disclosure or web attacks.	Run automated checks to identify and fix missing security headers.	Cannot detect complex custom logic flaws.

Day 2 — Protocol and Component Specification

Part C — Protocol Design

Message Structure: Delimiter-based text format (COMMAND|arg1|arg2).

Authentication and MFA sequence: Sequential SHA-256 password check followed by pyotp TOTP validation.

Authorization Rules: Sensitive commands are strictly blocked until ACCESS_GRANTED.

Malformed Request Handling: Managed via string parsing and try-except exception blocks.

Error Responses: Standardized format using ERROR|message prefixes.

Session Termination: Closed via the EXIT command.

Security Limitations: Local stateful sockets implemented; TLS encryption proposed for future deployment.

Part D — Component Design

Port scanner

- **Inputs:** Target IP address or hostname and the port range.
- **Outputs:** List of open, closed, or filtered ports with a structured scan report.
- **Expected Behavior:** Utilizes TCP sockets or python-nmap to probe target ports, rapidly determining listening states and returning structured results to the client user interface.
- **Failure Conditions:** Unreachable target host, network timeout, or filtered by the firewall.
- **Security Controls:** Strict target range restriction to ensure scans are limited exclusively to local test environments or explicitly authorized targets.

MFA module

- **Inputs:** Username, password, and Time-based One-Time Password (TOTP) token.
- **Outputs:** Authentication status.
- **Expected Behavior:** The server securely compares the submitted password, validates the 6-digit TOTP token, and grants access to protected commands only upon successful dual-factor verification.
- **Failure Conditions:** Invalid password, expired or incorrect TOTP token, or account lockout triggered by consecutive authentication failures.
- **Security Controls:** Secure password hashing storage and TOTP implemented.

HTTP checker

- **Inputs:** Local test website URL.
- **Outputs:** HTTP response header analysis report.
- **Expected Behavior:** Employs Python's requests library to send HTTP requests to the test website, examines response headers and basic configurations, and reports findings.
- **Failure Conditions:** Local test server error, connection refused, or unresolvable target URL.
- **Security Controls:** Avoiding any destructive exploits or injection attacks.

PCAP analyzer

- **Inputs:** Offline traffic capture file.
- **Outputs:** Suspicious pattern detection results.

- **Expected Behavior:** Leverages Scapy to read the PCAP file, iterate through packets, extract protocol-layer information, identify anomalous traffic patterns, and generate a structured analysis report
- **Failure Conditions:** Incorrect file path, corrupted PCAP file format, or missing Scapy library dependencies.
- **Security Controls:** Sandboxed offline analysis

Sensitive Information

Avoid collecting or logging user plain-text passwords and TOTP secret tokens. It is justified by security best practices to prevent credential disclosure and information leakage if log files are compromised, ensuring sensitive authentication material is never stored in persistent storage or logs.

Day 3 — Implementation, Testing, and Analysis

Part E — Full Integrated Implementation

1. **TCP connection establishment, framed or otherwise unambiguous message exchange, and command processing.**

```
PS D:\FSCT\FSCT-8561\FSCT8561-Midterm-Kuangda-Zhu> python .\client.py
Maximum failed attempts: 3


Enter your username: Alice
Enter your Password:
Attempt 1 → OTP_REQUIRED
Enter your code: 714926
Attempt 1 → ACCESS_GRANTED

    Please select a number:
    1. Port scanner
    2. HTTP checker
    3. PCAP Analyzer
    4. Exit

    Your selection:
```

   As shown in the image, the client successfully connected to the server and entered command interaction.

2. **Password verification using a secure password-hashing approach and TOTP-based MFA; protect authenticated server operations.**
   As shown in the first image, the client requires MFA to log in successfully.

3. **Rejection of unauthenticated or unauthorized requests to protected server functions**

```
PS D:\FSCT\FSCT-8561\FSCT8561-Midterm-Kuangda-Zhu> python .\client.py
Maximum failed attempts: 3


Enter your username: bbb
Enter your Password:
Attempt 1 → ERROR|User not exisits
Enter your username: Alice
Enter your Password:
Attempt 2 → ERROR|Incorrect password
Enter your username: Alice
Enter your Password:
Attempt 3 → OTP_REQUIRED
Enter your code: 123456
Attempt 3 → ACCESS_DENIED

Too many failed attempts.
Authentication blocked.
Disconnected
PS D:\FSCT\FSCT-8561\FSCT8561-Midterm-Kuangda-Zhu>
```

As shown in the image, if the username does not exist, the password is incorrect, or the TOTP code is invalid, the system rejects the request, preventing the user from accessing the command interface or calling any protected server functions.

4. **Client-side TCP port scanning of an instructor-authorized range that includes the student server's listening port.**

```
PS D:\FSCT\FSCT-8561\FSCT8561-Midterm-Kuangda-Zhu> python .\client.py
Maximum failed attempts: 3


Enter your username: Alice
Enter your Password:
Attempt 1 → OTP_REQUIRED
Enter your code: 843401
Attempt 1 → ACCESS_GRANTED

    Please select a number:
    1. Port scanner
    2. HTTP checker
    3. PCAP Analyzer
    4. Exit

    Your selection:
    1
Enter target host: localhost
Enter start port: 8760
Enter end port: 8770

Target:  127.0.0.1

PORT      STATE       SERVICE
8760      closed
8761      closed
8762      closed
8763      closed      mc-appserver
8764      closed      openqueue
8765      open        ultraseek-http
8766      closed      amcs
8767      closed      core-of-source
8768      closed      sandpolis
8769      closed      oktaauthenticat
8770      closed      apple-iphoto

Scan complete.
```

As shown in the image, the client successfully invoked the port scanner, scanned the local port range 8760–8770, and successfully detected an open port provided by the test environment.

5. **Client-side HTTP checks using requests against the supplied local test website.**

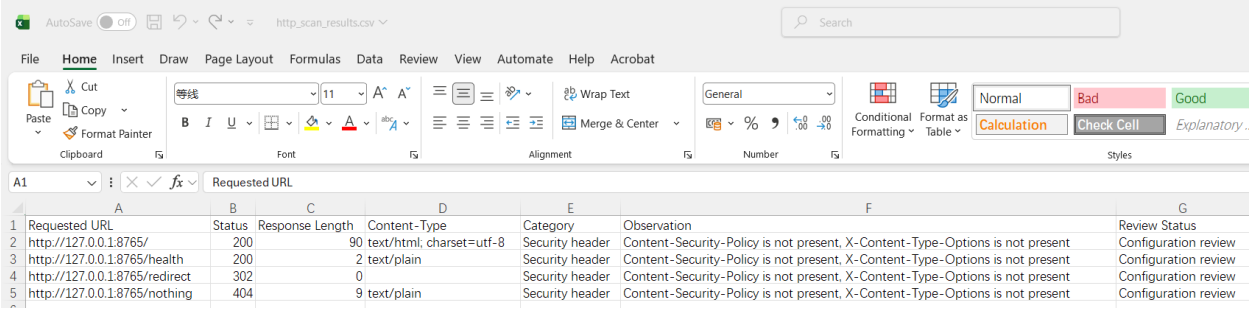
```
    Your selection:
    2
Enter target host: localhost
Enter port: 8765
Your target: http://127.0.0.1:8765
Enter the endpoint you want to check(Enter 0 if you want to quit):
Requested URL: http://127.0.0.1:8765/
Status: 200
Response Length: 90
Content-Type: text/html; charset=utf-8

Category: Security header
Observation: Content-Security-Policy is not present, X-Content-Type-Options is not present
Review Status: Configuration review
--------------------------------------------------------------------------------
Enter the endpoint you want to check(Enter 0 if you want to quit): health
Requested URL: http://127.0.0.1:8765/health
Status: 200
Response Length: 2
Content-Type: text/plain

Category: Security header
Observation: Content-Security-Policy is not present, X-Content-Type-Options is not present
Review Status: Configuration review
--------------------------------------------------------------------------------
Enter the endpoint you want to check(Enter 0 if you want to quit): redirect
Requested URL: http://127.0.0.1:8765/redirect
Status: 302
Response Length: 0
Content-Type: None

Category: Security header
Observation: Content-Security-Policy is not present, X-Content-Type-Options is not present
Review Status: Configuration review
--------------------------------------------------------------------------------
Enter the endpoint you want to check(Enter 0 if you want to quit): nothing
Requested URL: http://127.0.0.1:8765/nothing
Status: 404
Response Length: 9
Content-Type: text/plain

Category: Security header
Observation: Content-Security-Policy is not present, X-Content-Type-Options is not present
Review Status: Configuration review
--------------------------------------------------------------------------------
Enter the endpoint you want to check(Enter 0 if you want to quit): 0
```



	A	B	C	D	E	F	G
1	Requested URL	Status	Response Length	Content-Type	Category	Observation	Review Status
2	http://127.0.0.1:8765/	200	90	text/html; charset=utf-8	Security header	Content-Security-Policy is not present, X-Content-Type-Options is not present	Configuration review
3	http://127.0.0.1:8765/health	200	2	text/plain	Security header	Content-Security-Policy is not present, X-Content-Type-Options is not present	Configuration review
4	http://127.0.0.1:8765/redirect	302	0		Security header	Content-Security-Policy is not present, X-Content-Type-Options is not present	Configuration review
5	http://127.0.0.1:8765/nothing	404	9	text/plain	Security header	Content-Security-Policy is not present, X-Content-Type-Options is not present	Configuration review

As shown in the images, the HTTP checker used the requests library to query the local test website endpoints and successfully saved the response results into a CSV file.

6. **Server-side offline PCAP analysis using Scapy, including traffic summary and at least one justified suspicious-pattern detection.**

```
Enter the endpoint you want to check(Enter 0 if you want to quit): 0

    Please select a number:
    1. Port scanner
    2. HTTP checker
    3. PCAP Analyzer
    4. Exit

    Your selection:
    3
Please provide the pcap file (exit to back): FSCT8561_Operation_Sentinel_Traffic.pcap
--------------------------------------------------------------------------------
Traffic summary (First 5):
Source: 192.0.2.20 Destination: 192.0.2.10 Protocol: TCP Source port: 40000 Destination port: 5000
Source: 192.0.2.10 Destination: 192.0.2.20 Protocol: TCP Source port: 5000 Destination port: 40000
Source: 192.0.2.20 Destination: 192.0.2.10 Protocol: TCP Source port: 40000 Destination port: 5000
Source: 192.0.2.20 Destination: 192.0.2.10 Protocol: TCP Source port: 40001 Destination port: 5000
Source: 192.0.2.10 Destination: 192.0.2.20 Protocol: TCP Source port: 5000 Destination port: 40001

Total TCP packets: 5
Total UDP packets: 0


WARNING: Too many packets from 192.0.2.20

Total TCP packets: 113
Total UDP packets: 10
Total suspicious IPs: 1
--------------------------------------------------------------------------------
```

As shown in the image, the PCAP analyzer was invoked to analyze a PCAP file, first generating a summary of the first five traffic packets, and then analyzing the entire traffic to detect a suspicious IP address.

7. **Transmission of PCAP analysis results from server to client.**

```
Received: PCAP|FSCT8561_Operation_Sentinel_Traffic.pcap
```

As shown in the image, the server received the PCAP request.

8. **Input validation, meaningful error handling, and security-event logging without recording passwords or OTPs.**

```
PS D:\FSCT\FSCT-8561\FSCT8561-Midterm-Kuangda-Zhu> python .\server.py
Server is waiting for a connection...
Connected by: ('127.0.0.1', 31039)
Received: AUTH|Alice|34bf5eb46102238cd554f7a41353c5278073442ea98f7c30db33aaa4621f99e2
Received: OTP|[Protected]
Received: PCAP|FSCT8561_Operation_Sentinel_Traffic.pcap
```

As shown in the image, all event logs are recorded on the server side, where passwords are securely hashed and OTPs are masked to prevent sensitive data exposure.

Part F — Comprehensive Testing

Test1 – User Not Exists

Expected Result: Fail to login

Actual Result: Fail to login

Status: Pass

Evidence:

```
Enter your username: Kuangda
Enter your Password:
Attempt 1 → ERROR|User not exisits
Enter your username:
```

Test2 – Invalid Password

Expected Result: Fail to login

Actual Result: Fail to login

Status: Pass

Evidence:

```
Enter your username: Alice
Enter your Password:
Attempt 2 → ERROR|Incorrect password
Enter your username:
```

Test3 – Invalid OTP

Expected Result: Fail to login

Actual Result: Fail to login

Status: Pass

Evidence:

```
Enter your username: Alice
Enter your Password:
Attempt 1 → OTP_REQUIRED
Enter your code: 123146
Attempt 1 → ACCESS_DENIED
Enter your code:
```

Test4 – Too many attempts

Expected Result: Block the client

Actual Result: Block the client

Status: Pass

Evidence:

```
Enter your username: Alice
Enter your Password:
Attempt 1 → OTP_REQUIRED
Enter your code: 123146
Attempt 1 → ACCESS_DENIED
Enter your code: a
Attempt 2 → ACCESS_DENIED
Enter your code: s
Attempt 3 → ACCESS_DENIED
```

Test5 – Open Port Scan

Expected Result: Find the open port

Actual Result: Find the open port

Status: Pass

Evidence:

```
Enter target host: localhost
Enter start port: 8763
Enter end port: 8766

Target:  127.0.0.1

PORT      STATE       SERVICE
8763      closed      mc-appserver
8764      closed      openqueue
8765      open        ultraseek-http
8766      closed      amcs

Scan complete.

    Please select a number:
    1. Port scanner
    2. HTTP checker
    3. PCAP Analyzer
    4. Exit

    Your selection:
```

Test6 – Closed Port Scan

Expected Result: Find the closed port

Actual Result: Find the closed port

Status: Pass

Evidence:

```
Enter target host: localhost
Enter start port: 5000
Enter end port: 5005

Target:  127.0.0.1

PORT      STATE       SERVICE
5000      closed      upnp
5001      closed      commplex-link
5002      closed      rfe
5003      closed      filemaker
5004      closed      avt-profile-1
5005      closed      avt-profile-2

Scan complete.
```

Test7 - HTTP Checker & CSV

Expected Result: Print a structured report and a CSV file

Actual Result: Print a structured report and a CSV file

Status: Pass

Evidence:

```
Enter target host: localhost
Enter port: 8765
Your target: http://127.0.0.1:8765
Enter the endpoint you want to check(Enter 0 if you want to quit):
Requested URL: http://127.0.0.1:8765/
Status: 200
Response Length: 90
Content-Type: text/html; charset=utf-8

Category: Security header
Observation: X-Content-Type-Options is not present, Content-Security-Policy is not present
Review Status: Configuration review
--------------------------------------------------------------------------------
Enter the endpoint you want to check(Enter 0 if you want to quit): redirect
Requested URL: http://127.0.0.1:8765/redirect
Status: 302
Response Length: 0
Content-Type: None

Category: Security header
Observation: X-Content-Type-Options is not present, Content-Security-Policy is not present
Review Status: Configuration review
--------------------------------------------------------------------------------
Enter the endpoint you want to check(Enter 0 if you want to quit): health
Requested URL: http://127.0.0.1:8765/health
Status: 200
Response Length: 2
Content-Type: text/plain

Category: Security header
Observation: X-Content-Type-Options is not present, Content-Security-Policy is not present
Review Status: Configuration review
--------------------------------------------------------------------------------
Enter the endpoint you want to check(Enter 0 if you want to quit): nothing
Requested URL: http://127.0.0.1:8765/nothing
Status: 404
Response Length: 9
Content-Type: text/plain

Category: Security header
Observation: X-Content-Type-Options is not present, Content-Security-Policy is not present
Review Status: Configuration review
--------------------------------------------------------------------------------
Enter the endpoint you want to check(Enter 0 if you want to quit): 0
```

A	B	C	D	E	F	G	H
Requestec	Status	Response	Content-T	Category	Observati	Review Status	
http://127	200	90	text/html;	Security h	X-Conten	Configuration review	
http://127	302	0		Security h	X-Conten	Configuration review	
http://127	200	2	text/plain	Security h	X-Conten	Configuration review	
http://127	404	9	text/plain	Security h	X-Conten	Configuration review	

Test8 - PCAP Analysis & Detection

Expected Result: Print a traffic summary and result of detection

Actual Result: Print a traffic summary and result of detection

Status: Pass

Evidence:

```
Please provide the pcap file (exit to back): FSCT8561_Operation_Sentinel_Traffic.pcap
--------------------------------------------------------------------------------
Traffic summary (First 5):
Source: 192.0.2.20 Destination: 192.0.2.10 Protocol: TCP Source port: 40000 Destination port: 5000
Source: 192.0.2.10 Destination: 192.0.2.20 Protocol: TCP Source port: 5000 Destination port: 40000
Source: 192.0.2.20 Destination: 192.0.2.10 Protocol: TCP Source port: 40000 Destination port: 5000
Source: 192.0.2.20 Destination: 192.0.2.10 Protocol: TCP Source port: 40001 Destination port: 5000
Source: 192.0.2.10 Destination: 192.0.2.20 Protocol: TCP Source port: 5000 Destination port: 40001

Total TCP packets: 5
Total UDP packets: 0


WARNING: Too many packets from 192.0.2.20

Total TCP packets: 113
Total UDP packets: 10
Total suspicious IPs: 1
--------------------------------------------------------------------------------
```

Test9 – Invalid Input

Expected Result: Return an Error message and keep running

Actual Result: Return an Error message and keep running

Status: Pass

Evidence:

```
    Please select a number:
    1. Port scanner
    2. HTTP checker
    3. PCAP Analyzer
    4. Exit

    Your selection:
    5
Please enter a valid number.

    Please select a number:
    1. Port scanner
    2. HTTP checker
    3. PCAP Analyzer
    4. Exit

    Your selection:
    100
Please enter a valid number.
```

Test9 – Invalid Input

Expected Result: Return an Error message and keep running

Actual Result: Return an Error message and keep running

Status: Pass

Evidence:

```
    Please select a number:
    1. Port scanner
    2. HTTP checker
    3. PCAP Analyzer
    4. Exit

    Your selection:
    5
Please enter a valid number.

    Please select a number:
    1. Port scanner
    2. HTTP checker
    3. PCAP Analyzer
    4. Exit

    Your selection:
```

Test10 – Disconnect the Server

Expected Result: The server disconnected gracefully

Actual Result: The server disconnected gracefully

Status: Pass

Evidence:

```
    Your selection:
    4
Server: OK|Goodbye
Disconnected
```

```
PS D:\FSCT\FSCT-8561\FSCT8561-Midterm-Kuangda-Zhu> python .\server.py
Server is waiting for a connection...
Connected by: ('127.0.0.1', 47176)
Received: AUTH|Alice|34bf5eb46102238cd554f7a41353c5278073442ea98f7c30db33aaa4621f99e2
Received: OTP|[Protected]
Received: PCAP|FSCT8561_Operation_Sentinel_Traffic.pcap
Received: EXIT|
Server closed
```

Part G — Security Analysis and Reflection

9. **Which threats from your Day 1 model did your implementation mitigate, and which remain?**
   The implementation mitigated plaintext sniffing, brute-force attacks, unauthorized scanning, and PCAP DoS via password hashing, TOTP MFA, target bounds, and limits, while residual risks like host memory reading and zero-day vulnerabilities remain.
10. **What suspicious traffic did your PCAP analyzer identify? Cite packet-level or summary evidence.**
    The PCAP analyzer detected suspicious traffic from IP 192.0.2.20 based on the warning message and its disproportionately high packet count in the summary statistics.
11. **What did your HTTP checker find, and why are its findings not proof of exploitability?**
    The HTTP checker identified missing security headers like Content-Security-Policy and X-Content-Type-Options, which indicates a security configuration weakness rather than proof of direct exploitability.
12. **What are the confidentiality and replay limitations of a plain TCP connection, even with TOTP MFA?**
    Plain TCP lacks encryption, exposing session data to eavesdropping, while missing dynamic session tokens leaves the connection vulnerable to session hijacking despite TOTP MFA.
13. **What would you improve before deploying this application in production?**
    Before production deployment, I would implement TLS/SSL encryption.

Github

https://github.com/bnwzc/FSCT8561-Midterm-Kuangda-Zhu